

Capital.com Public API - Authentication & Session

Part 1 for CapitalDemoBroker / Codex

Prepared from the official Capital.com Public API 1.0.0 documentation. This is a developer-oriented reference: technical identifiers, endpoints, fields and constraints are preserved; descriptive prose is condensed rather than reproduced verbatim.

1. Base addresses and API path

Item	Value
LIVE REST base	https://api-capital.backend-capital.com/
DEMO REST base	https://demo-api-capital.backend-capital.com/
REST API prefix	/api/v1
Streaming endpoint	wss://api-streaming-capital.backend-capital.com/connect
API documentation version	1.0.0

2. Session lifetime and rate limits

- A REST session remains active for 10 minutes after the last use. After longer inactivity, a new session is required.
- POST /session is limited to 1 request per second per API key.
- General maximum request rate: 10 requests per second per user.
- When opening positions or creating orders: maximum 1 request per 0.1 seconds per user.
- On DEMO, POST /positions and POST /workingorders are limited to 1000 requests per hour.

3. Authentication model

A session can be created with the API key plus login identifier and the custom password assigned to the API key. The password may be sent directly (encryptedPassword=false) or encrypted after retrieving the public encryption key.

4. Get encryption key

GET /api/v1/session/encryptionKey

Header:

X-CAP-API-KEY: YOUR_API_KEY

DEMO:

<https://demo-api-capital.backend-capital.com/api/v1/session/encryptionKey>

LIVE:

<https://api-capital.backend-capital.com/api/v1/session/encryptionKey>

Response fields:

```
{
  "encryptionKey": "...",
  "timeStamp": 1649058606014
}
```

For encrypted authentication, Capital.com instructs the client to obtain encryptionKey and timeStamp first, encrypt the API-key custom password using the documented RSA-based procedure, then call POST /session with encryptedPassword=true.

5. Create new session

POST /api/v1/session

Header:

X-CAP-API-KEY: YOUR_API_KEY

Content-Type: application/json

Body:

```
{
  "identifier": "YOUR_LOGIN",
  "password": "YOUR_PASSWORD",
  "encryptedPassword": false
}
```

DEMO:

https://demo-api-capital.backend-capital.com/api/v1/session

LIVE:

https://api-capital.backend-capital.com/api/v1/session

Field	Type	Required	Meaning
identifier	string	YES	Client login identifier
password	string	YES	API-key custom password (or encrypted value)
encryptedPassword	boolean	NO	Whether password is encrypted; default false

Documented response classes for session creation: 200 OK, 400 Bad Request, 401 Unauthorized, 429 Too Many Requests.

After successful session creation, two security values are returned in response headers: CST and X-SECURITY-TOKEN. CST identifies the client session; X-SECURITY-TOKEN identifies the financial account used for trading. Both must be sent on subsequent authenticated REST requests.

6. Session response data

Typical body fields documented for a successful session:

```
{
  "accountType": "CFD",
  "accountInfo": {
    "balance": ...,
    "deposit": ...,
    "profitLoss": ...,
    "available": ...
  },
  "currencyIsoCode": "USD",
  "currencySymbol": "$",
  "currentAccountId": "...",
  "streamingHost": "wss://api-streaming-capital.backend-capital.com/",
  "accounts": [...],
  "clientId": "...",
  "timezoneOffset": 3,
  "hasActiveDemoAccounts": true,
  "hasActiveLiveAccounts": true,
  "trailingStopsEnabled": false
}
```

Response headers:

CST: REDACTED_CST

X-SECURITY-TOKEN: REDACTED_SECURITY_TOKEN

7. Check current session

GET /api/v1/session

Headers:
CST: REDACTED_CST
X-SECURITY-TOKEN: REDACTED_SECURITY_TOKEN

Documented response fields include:
clientId
accountId
timezoneOffset
locale
currency
streamEndpoint

8. Keep session alive

GET /api/v1/ping

Headers:
CST: REDACTED_CST
X-SECURITY-TOKEN: REDACTED_SECURITY_TOKEN

Response:
{
 "status": "OK"
}

9. Switch active financial account

PUT /api/v1/session

Headers:
CST: REDACTED_CST
X-SECURITY-TOKEN: REDACTED_SECURITY_TOKEN
Content-Type: application/json

Body:
{
 "accountId": "DEMO_ACCOUNT"
}

Capital.com notes that changing the financial account via PUT /session causes WebSocket streaming to fall off, so a broker adapter should treat an account switch as requiring streaming reconnection/resubscription.

10. Log out

DELETE /api/v1/session

Headers:
CST: REDACTED_CST
X-SECURITY-TOKEN: REDACTED_SECURITY_TOKEN

Successful example:
{
 "status": "SUCCESS"
}

11. Accounts relevant to authentication

GET /api/v1/accounts returns the financial accounts belonging to the authenticated client. GET /api/v1/accounts/preferences returns account preferences including trading mode. The hedgingMode preference is important for a strategy that needs simultaneous LONG and SHORT exposure.

12. CapitalDemoBroker implementation rules confirmed by documentation

- Use the DEMO host explicitly; do not derive LIVE/DEMO by an unsafe runtime guess.

- Treat /api/v1 as part of the REST endpoint path.
- Store CST and X-SECURITY-TOKEN separately and attach both to authenticated requests.
- Expire/re-authenticate a locally idle session at the documented 10-minute boundary rather than assuming indefinite token validity.
- Respect the 1 request/second POST /session limit.
- Do not expose API key, login, API-key password, CST or X-SECURITY-TOKEN in logs.
- If the active account changes, reconnect streaming before trusting further streaming state.
- Trading POST retry behavior is NOT established by the authentication section alone; ambiguous trade outcomes must later be resolved using the deal-confirmation contract rather than blind replay.

13. Source

Official source: Capital.com Public API 1.0.0 - <https://open-api.capital.com/> (Authentication, Session, General information, FAQ, Accounts sections; accessed 10 Aug 2026).